

Section #1: **Why Healthcare**

Core Reference:

“A systematic analysis of failures in protecting personal health data: A scoping review” — a scoping review of 120 articles (drawn from 5,470 records), published in February 2024 in *International Journal of Information Management* [ResearchGateScienceDirect](#).

Key Reasons Highlighted:

1. High Sensitivity and Value of Data

Personal health information (PHI), especially digital medical records, isn't just personal—it's critical. Its exposure can compromise patient safety, trust, and regulatory standing, making healthcare systems uniquely high-stakes.

2. Systemic and Regional Vulnerabilities

The review identifies persistent, systemic weaknesses: outdated infrastructures, weak encryption, human factors (e.g., insufficient staff training), and uneven policy implementation across regions (HIPAA, GDPR, POPIA, etc.) [Consensus](#).

3. Regulatory Pressure and Trust Imperative

Compliance with laws (HIPAA in the U.S., GDPR in Europe, POPIA in South Africa) is necessary but often insufficient—cases like Anthem, SingHealth, and WannaCry remind us: regulations alone can't protect against breaches. Trust is essential and easily broken [ConsensusPMC](#).

4. Technological and Organizational Gaps

Even regions with strong regulatory frameworks suffer breaches due to technological faults and organizational issues—legacy systems, poor patching, minimal monitoring—making proactive, intelligent detection a need, not a luxury [ConsensusPMC](#).

Narrative Synthesis for Literature Review:

Healthcare systems hold the most sensitive, regulated data—medical histories, diagnoses, treatment plans. Securing that data is uniquely complex, spanning legal mandates (HIPAA, GDPR), institutional shortcomings (outdated IT, misconfigurations), and socio-technical gaps (awareness, training). A scoping review analyzing over 5,000 records and synthesizing 120 studies revealed that breaches in healthcare are not isolated failures but reflect structural and systemic vulnerabilities across global contexts [ResearchGateConsensusPMC](#). These breaches erode patient trust, roll back hard-won compliance gains, and threaten patient safety.

Justification for EHR Focus:

- The combination of **valuable target (PHI)**, **regulatory burden**, and **systemic weaknesses** makes EHR systems especially ripe for novel detection techniques.
- Generic security solutions often fall short; healthcare requires **behavior-aware, explainable models** that respect legal and operational constraints.
- Data privacy in healthcare is not just technical—it's ethical, legal, and foundational to the doctor–patient relationship.

Section #2: **Why Behavioral Fingerprinting?**

Core Reference:

“Integrated Dynamic Behavioral Fingerprinting for Real-Time Ransomware Detection: A Pattern-Based Classification” (2024).

Key Insights:

1. Shift from Static to Behavioral Approaches

Traditional signature- or rule-based systems fail against polymorphic, obfuscated, or zero-day attacks. Behavioral fingerprinting instead models *how entities act*, not just *what they look like*. In ransomware detection, that means spotting patterns of file encryption, system calls, or network anomalies regardless of specific binary.

2. Unique, Repeatable Patterns

Every malicious process tends to leave a reproducible “behavioral fingerprint.” Even if payloads differ, the underlying sequence of actions (e.g., enumerating directories, mass file writes, shadow copy deletion) is consistent. The paper shows that such fingerprints are discriminative enough for real-time classification.

3. Dynamic and Adaptive Detection

The proposed system builds **dynamic fingerprints** that update during execution, enabling detection of evolving threats mid-flight. This dynamic aspect avoids reliance on prior knowledge and allows timely responses.

4. Explainability and Interpretability

Pattern-based fingerprints are inherently interpretable: security analysts can see *which sequence of actions led to a flag*. This aligns strongly with domains like healthcare, where compliance requires transparent justification for any intervention.

Narrative Synthesis for Literature Review:

Modern threat landscapes highlight the inadequacy of static, signature-based detection, particularly against zero-day exploits and evasive malware. Behavioral fingerprinting has emerged as a paradigm that captures *how entities behave* rather than *what they contain*. By encoding sequences of actions into unique, dynamic “fingerprints,” behavioral models enable real-time, adaptive threat detection that generalizes across attack variants.

A recent ransomware-focused study demonstrates the efficacy of **pattern-based classification via dynamic behavioral fingerprints**, showing that such models not only detect known strains but also adapt to new ones through their reproducible activity profiles. Unlike opaque machine-learning classifiers, fingerprints provide **transparency and interpretability**, allowing analysts to reason about why an event is flagged ([OSF preprint](#)).

Justification for EHR Focus:

- EHR environments generate **rich, sequential user activity** (logins, record views, prescription updates).
- Attacks against EHRs similarly manifest as *behavioral anomalies*: brute-force logins, privilege escalations, unauthorized record exports.
- Behavioral fingerprinting thus provides a **domain-appropriate lens**:
 - Works without needing vast labeled datasets of healthcare attacks (rare due to HIPAA).
 - Produces interpretable activity patterns for regulatory compliance.
 - Enables continuous, adaptive monitoring in clinical workflows.

Section #3.1: Why Graph Modeling (over CAPEC)

Core Reference: *A Design and Development of Web Application Vulnerability Detection Using Graph-Based Modeling Analysis Over CAPEC*

Key Points:

1. Limitations of Traditional Tools

- Conventional VA scanners or SIEMs produce flat lists of vulnerabilities.
- They rarely reveal the *attack patterns* or correlations between events in logs.
- In healthcare (and other regulated fields), *understanding the chain of actions* matters as much as detection.

2. Role of CAPEC

- CAPEC provides a hierarchical taxonomy of attack patterns.
- It enables classification of threats not just by weakness (CWE) or specific instance (CVE) but by *attacker behavior*.
- This aligns with your **fingerprinting** approach: “what pattern of actions is happening?”

3. Why Graphs?

- Logs are inherently relational: IP → URL → parameter → error code.
- CAPEC attack patterns are also relational: steps, sub-techniques, dependencies.
- Graph representation allows merging logs + CAPEC into one structure.
- Subgraph isomorphism = natural way to check: “Does this user activity look like a known attack pattern?”

4. Demonstrated Benefits (per the paper)

- Graph modeling uncovers subtle relationships that would be missed in linear scans.
- Improves detection efficiency by storing and querying patterns structurally.
- Scales with many log files and patterns without exploding false positives.

Narrative for Lit Survey:

Graph modeling is particularly well-suited for capturing the structural and sequential nature of attack patterns. By transforming both logs and CAPEC-derived attack descriptions into graphs, vulnerabilities can be detected via subgraph matching rather than linear signature scans. This approach enables a richer, more holistic view of threats—linking disparate log attributes (IP, URL, error message) into meaningful chains. In domains like healthcare, where user actions must be auditable and explainable, graph-based representations provide transparency and precision unavailable to traditional black-box or purely statistical detectors.

Section #3.2: How to Construct the Fingerprint DB (Tracing CVE → CAPEC)

Core Reference: *The Challenging Task of Tracing CVEs to CAPEC* (University of Hawai‘i, 2022)

Key Points:

1. Problem Statement

- CAPEC describes *attack patterns* (high-level behaviors).

- CVE describes *specific vulnerabilities*.
- Linking the two is essential for building a practical fingerprint DB.
- But mappings are sparse, inconsistent, and sometimes missing entirely.

2. Challenges Identified

- One CAPEC can map to many CVEs (e.g., “SQL Injection” CAPEC → hundreds of CVEs).
- One CVE can relate to multiple CAPECs (multi-step or composite attacks).
- No universal automated method—requires semi-automated text mining, ontology alignment, and expert curation.

3. Methods Proposed

- Use textual similarity (NLP) between CVE descriptions and CAPEC definitions.
- Leverage intermediary CWE (weakness) IDs since CVEs almost always map to CWE, and many CWEs map to CAPEC.
- Store mappings in a **graph DB** where nodes = {CVE, CWE, CAPEC}, edges = “is mapped to.”
- This becomes the **attack fingerprint DB**: a structured link between real-world vulnerabilities and abstract patterns.

4. Relevance to Your Project

- You already built a CVE dataset filtered by healthcare.
- Next step: link those CVEs → CWE → CAPEC → Graph template.
- This creates your **fingerprint repository** that can be used for subgraph matching against EHR user activity graphs.

Narrative for Lit Survey:

Constructing a usable fingerprint database requires bridging abstract attack models (CAPEC) with concrete vulnerabilities (CVEs). This process is non-trivial: mappings are many-to-many, incomplete, and often inconsistent. Prior work highlights that CWE serves as a useful “pivot” for semi-automated linking. By encoding CAPEC, CWE, and CVE entities as nodes within a graph database, and enriching them with textual and semantic similarity scores, researchers can gradually build a reliable corpus of fingerprints. This approach transforms isolated vulnerability records into structured behavioral templates, enabling their application in real-world anomaly detection systems such as EHRs.

4.1 Hidden Markov Models (Phase I – Sequence-based Detection)

Core Reference: *Attack Plan Recognition Using Hidden Markov and Probabilistic Inference* (Computers & Security, 2020).

Key Points:

- **Why HMMs?**
 - HMMs model user behavior as sequences of observable actions (click, query, file access).
 - Hidden states represent *intent* (benign vs malicious progression).
 - Probabilistic inference allows prediction of the most likely attack plan given partial observations.
- **Mechanism:**
 - Training phase: feed HMMs with known benign and attack sequences (from CAPEC-derived graphs).
 - Recognition phase: as new user activity streams in, calculate likelihood of belonging to an attack sequence vs benign.
 - Output: probability scores → “abnormal if $P(\text{malicious}) > \text{threshold}$.”
- **Why Phase I?**
 - HMMs are lightweight, interpretable, and work well when attack plans are sequential and relatively simple (credential brute force, privilege abuse).
 - Suitable for your Phase I prototype where users interact with a simulated EHR and activity is mostly linear (login → query → update).
- **Narrative for Lit Survey:**

Hidden Markov Models (HMMs) provide a statistical foundation for early-stage anomaly detection by treating user actions as observable sequences governed by hidden attacker intent. Prior research demonstrates that HMMs are capable of recognizing multi-step attack plans even under uncertainty. In the context of EHR activity, HMMs can be trained to model normal clinical workflows (patient lookup, record update) versus suspicious patterns (repeated failed logins, abnormal queries). This makes HMMs a natural choice for Phase I, where the focus is lightweight, real-time recognition of abnormal user sequences.

4.2 Graph Neural Networks & Subgraph Matching (Phase II – Structural Detection)

Core Reference: *GHunter: A Fast Subgraph Matching Method for Threat Hunting* (IEEE, 2023).

Key Points:

- **Why GNN + Subgraph Matching?**
 - Attack behavior is not always linear; it can branch, loop, or combine multiple attack patterns.
 - Graph Neural Networks (GNNs) embed structural patterns of attacks for efficient similarity search.
 - Subgraph matching compares observed user activity graphs against known attack templates (from CAPEC/CVE fingerprints).
- **Mechanism:**
 - Build graph fingerprints of attacks (CAPEC pattern → nodes and edges).
 - Construct user activity graphs dynamically as EHR users interact.
 - Apply GHunter-style methods for fast subgraph matching to detect whether suspicious motifs (e.g., privilege escalation + injection attempt) exist inside activity graphs.
 - Unlike HMMs, this captures *complex branching and relational attack structures*.
- **Why Phase II?**
 - Phase II introduces deception layers (Digital Twin + honeytokens).
 - Need more expressive models to detect sophisticated, branching attacks.
 - GNN-based subgraph matching supports scalability across large, evolving user activity datasets while maintaining accuracy.
- **Narrative for Lit Survey:**

Graph-based learning methods such as Graph Neural Networks (GNNs) extend detection capabilities beyond sequential patterns to structural, multi-relational activity graphs. Recent work such as GHunter shows that subgraph matching can be accelerated significantly using GNN embeddings, enabling practical deployment in real-time threat hunting. In Phase II of the project, where user activity graphs become richer and deception environments are introduced, GNN-based subgraph matching is better suited than HMMs to detect advanced, multi-step attack strategies. This ensures scalability, precision, and adaptability in the healthcare context, where threats often involve correlated actions spanning multiple system components.

Dimension	Hidden Markov Models (HMMs)	Graph Neural Networks (GNNs) + Subgraph Matching
Core Principle	Sequential probabilistic modeling (states & transitions)	Structural learning on graphs with embeddings & matching
Data Representation	User actions as ordered sequences (time-series)	User actions as nodes + relations (graph structures)
Expressiveness	Captures simple sequential workflows (linear)	Captures complex branching, loops, multi-relational behaviors
Training Data Needs	Moderate – requires labeled benign vs attack sequences	High – requires graph datasets + CAPEC/CVE mappings
Detection Style	Likelihood-based anomaly scoring	Subgraph isomorphism / similarity search
Scalability	Lightweight, efficient in real-time	More computationally expensive, but scalable with optimizations (e.g., GHunter)
Interpretability	High – transition probabilities can be explained	Lower – embeddings harder to explain, needs XAI methods
Best For	Phase I: Prototype with simulated EHR logs and simple attack paths	Phase II: Realistic, large-scale healthcare system with deception + complex attack graphs
Limitations	Struggles with non-linear/branching behavior	Requires more compute, harder to deploy on constrained systems
Example Application	Detect brute-force login or abnormal query sequences	Detect multi-step attacks combining privilege escalation + injection + lateral movement

Section #5: Deception with Digital Twins (DT) and HoneyTokens (HT)

5.1 Digital Twins + Cyber Deception

Core Reference: *Interplay of Digital Twins and Cyber Deception: Unraveling Paths for Technological Advancements*

Key Points:

- **Digital Twins (DTs)** are high-fidelity virtual replicas of systems synchronized with real assets.
- **Honeypots / Honeytokens (HTs)** are deliberately exposed decoys to attract, mislead, and study attackers.
- Combining DT + HT allows defenders to *both engage attackers and protect real systems*.
- **Why this matters for EHRs:**
 - Healthcare records are highly regulated; direct attacker interaction with live systems is unacceptable.
 - A DT of the EHR can simulate the real environment with realistic (but synthetic) patient records.
 - HTs embedded in the DT (fake credentials, bogus patient data) lure attackers while shielding the real system.
- **Framework Functions (as proposed in literature):**
 1. **Mimic** → Build DT replicas of EHR components (login portals, patient DB).
 2. **Attract** → Place HTs like fake admin accounts, weak passwords, or bogus HL7 messages.
 3. **Deploy** → Host these DT + HT assets alongside the live system.
 4. **Engage** → Let attackers interact with the DT, prolonging engagement.
 5. **Monitor** → Log attacker actions for forensic insights.
 6. **Reset** → Restore the DT environment after compromise, ensuring repeatability.
 7. **Analyze** → Feed attacker behavior into the fingerprint DB, strengthening Phase I detection.
- **SWOT Analysis (condensed from the paper):**
 - *Strengths:* Improved control over attackers, low deployment cost with virtualization, enhanced visibility.
 - *Weaknesses:* Fidelity challenge (DTs must be realistic but not leak sensitive structure).

- *Opportunities*: Standardization, multi-domain applicability (healthcare, finance, ICS).
- *Threats*: Sophisticated attackers may detect honeypots; DTs themselves may expand attack surface.

5.2 Explainable AI (XAI) for Cyber Deception

Core Reference: *Explainable AI (XAI) for Cyber Defense* (2024)

Key Points:

- GNN-based subgraph detection (Phase II) often acts as a “black box.”
- Healthcare domain requires *auditability* to comply with HIPAA and ensure clinician trust.
- XAI provides interpretability by:
 - Highlighting which subgraph (e.g., “abnormal login → SQL injection → privilege escalation”) triggered the alert.
 - Allowing admins to trace attack paths step by step.
 - Justifying alerts for both compliance officers and system operators.
- **Relevance:**
 - In Phase I, HMMs already offer interpretability (transition probabilities).
 - In Phase II, when GNNs flag abnormal subgraphs, XAI must explain *why* that pattern matched malicious fingerprints.
 - This ensures healthcare adoption, where false alarms or unexplained alerts can directly disrupt clinical workflows.

Narrative for Literature Survey:

Digital Twins (DTs) and Honeytokens (HTs) represent the transition from pure detection to active adversary engagement. By diverting attackers into lifelike but controlled environments, defenders can safely observe behavior and strengthen detection models without risking live systems. In healthcare, DT-based deception can replicate EHR workflows with synthetic patient data, balancing realism and privacy. Honeytokens enrich this deception by embedding bait credentials and records that expose intruders upon access. However, realism must be carefully managed—too much fidelity risks information leakage, while too little fidelity risks attacker disengagement.

To ensure these mechanisms gain clinical acceptance, Explainable AI (XAI) is indispensable. While HMMs offer inherent interpretability in Phase I, Phase II's reliance on GNN-based subgraph detection introduces opacity. XAI methods bridge this gap, ensuring that abnormal activity alerts can be traced back to specific suspicious behaviors and justified under compliance frameworks. Together, DTs, HTs, and XAI form the foundation of Phase II: deception-enhanced, explainable, and domain-aware security for EHR systems.

Section #6: Synthesis and Research Gap Identification

6.1 Synthesis Across Themes

From the literature reviewed, several consistent themes emerge:

1. Healthcare as a Prime Target

- Personal health data is among the most sensitive and valuable, making healthcare systems disproportionately targeted.
- Systemic weaknesses (legacy IT, poor patching, uneven compliance) persist despite HIPAA/GDPR mandates.
- Healthcare-specific protocols (HL7, DICOM, FHIR) introduce unique vulnerabilities absent in other domains.

2. Behavioral Fingerprinting as a Viable Paradigm

- Moving away from static signatures, behavioral fingerprints capture reproducible patterns of activity.
- They provide adaptability against polymorphic or zero-day attacks while remaining interpretable.
- Healthcare user workflows (patient lookup, prescription updates, billing) align well with behavioral modeling.

3. Graph Modeling for Attack Representation

- CAPEC and CVE can be structurally represented as graphs, enabling subgraph matching with user activity.
- Graphs preserve the relational and sequential nature of attacks, offering more nuanced detection than flat signatures.
- Fingerprint databases that link CVEs → CWEs → CAPECs operationalize this approach.

4. Algorithms for Detection: Sequence vs Structure

- HMMs (Phase I) are efficient and interpretable for sequential, linear workflows (logins, queries).
- GNN-based subgraph matching (Phase II) scales to more complex, branching attack patterns.
- Together, they provide a roadmap: start lightweight, then expand to sophisticated detection.

5. Deception and Explainability

- Digital Twins + Honeytokens redirect attackers into controlled, realistic environments.
- Deception aligns with healthcare privacy requirements, as synthetic patient data can safely simulate targets.
- Explainable AI ensures alerts are transparent, auditable, and regulatorily defensible.

6.2 Identified Gaps

- **Healthcare-Specific Fingerprint Corpus:**
While CAPEC/CVE-based fingerprinting is conceptually rich, few works tailor this to healthcare protocols and applications (EHR, PACS, HL7).
Gap: No existing curated healthcare-specific attack graph database.
- **Bridging Sequential and Structural Detection:**
Literature often isolates either HMM-based sequence analysis or GNN-based graph learning.
Gap: No integrated framework that evolves from interpretable sequence models (Phase I) to scalable graph models (Phase II).
- **Deception in EHR Context:**
Digital twins and honeytokens are studied generally but rarely in EHR workflows.
Gap: Lack of research on deception strategies that respect HIPAA constraints while remaining realistic.
- **Explainability for Compliance:**
XAI in cybersecurity is emerging, but its direct application to healthcare anomaly detection is underexplored.
Gap: No existing explainability framework tailored to clinicians and compliance officers.

6.3 Research Contribution of This Work

- **Domain-Specific Justification:** Focusing on EHRs is not arbitrary; it is grounded in the value, regulatory weight, and vulnerability of healthcare systems.
- **Novel Fingerprinting Approach:** Creation of a **healthcare attack fingerprint DB** linking CVEs → CWEs → CAPECs, integrated with user activity graphs.
- **Dual-Phase Methodology:**
 - **Phase I:** HMM-based detection for simulated EHR logs.
 - **Phase II:** GNN-based subgraph matching with deception layers (DT + HT).
- **Explainability Integration:** Ensures findings are transparent, auditable, and regulatorily defensible.

Final Narrative for Literature Survey:

The reviewed works collectively highlight the insufficiency of traditional, static approaches for protecting healthcare systems. They also demonstrate the promise of behavioral fingerprinting, graph-based modeling, and advanced detection algorithms. Yet, critical gaps remain in domain adaptation, deception integration, and explainability. By focusing on EHRs, this project bridges these gaps—creating a domain-aware, interpretable, and deception-enabled framework for sandboxed behavioral fingerprinting.